

ENTRA ID SECURITY LAB

Environment	Microsoft Entra ID (Free Tier)
SIEM/Logging	Splunk Free
Report Date	Sep 5, 2026

Summary:

This report is self-directed study to learn practically. This lab is built entirely on free tier tooling such as: Microsoft Entra ID for identity and access management, and Splunk Free for log aggregation and detection.

The objective was to simulate real life attack patterns consisting of brute force, legacy auth and anomalous location sign ins. Then use the tools to detect, analyze and professionally report using the same workflow as SOC analyst would follow in a production.

Three simulated scenarios were investigated in depth: 20 attempt brute force lockout, a legacy authentication (ROPC), and a sign-in anomaly showing impossible travel patterns between Calgary and Singapore. Each is mapped to a corresponding MITRE ATT&CK technique below.

The lab environment consisted of 8-10 test users across mixed roles (administrative, standard staff, and contractor) to simulate a real-life organization. I made 4 users manually to understand how a user is made then after for efficiently I use AI to make 20 users. After users were created, I moved on to learn more about roles and least privilege role assignments such as Global Reader and User Administration, only 3 users were granted roles due to efficiency.

Roles and Justifications:

***Note:** each user may qualify for more than 1 or several roles, but for efficiency I limit to 1-3 roles max.*

User	Role	Why
Alex Rivera (IT Manager, IT)	Global Reader	Being an IT Manager, you should have access to most of stuff. But instead of Global Admin, where the user can change anything is not safe, keeping in mind the least privileged rule. Therefore, the highest 2 nd most important role would be sufficient.
Jordan Lee (IT Support Analyst, IT)	Attribute Log Administrator Security Administrator Service Support Administrator	Can analyze logs, information and reports and manage. Can also manage tickets. Mostly analyzing roles makes sense.
Taylor Morgan (Helpdesk Admin, IT)	User Administrator Helpdesk Administrator	Can manage users and reset passwords for limited admins. Can reset passwords and manage basic user issues. Matches support/helpdesk job function.

***Note:** Only the 3 users above (IT-Admins group) were assigned Entra ID roles. All other users remain standard members with no elevated access*

Detection Capabilities Built

MA = Microsoft Authenticator

User	MFA	Login Attempt Description	Result
Alex Rivera	MA	Legacy Auth Attempt: It can't support MFA at all, there's no step for "now approve on your phone," so if someone steals the password, they're in.	Tried EWS and IMAP, did not work, but ROPC flow worked, interestingly there is a filter to find ROPC on Entra but not the others, I think and researched that only ROPC remained intact, while others have retired, which did not give a flag.
Jordan Lee	MA	Brute force wrong password	Account locked
Morgan Patel	MA	Use VPN: before using a VPN on a user I need to log through my home account then use VPN to show change of network	Logs flag account was opened from a different location than the usual one

Incident 1: Legacy Authentication (ROPC) Sign-In

Summary:

Entra ID sign-in logs recorded an authentication event for user Alex Rivera using the ROPC protocol via Microsoft Azure PowerShell. ROPC is a legacy authentication flow in which the client application collects the user's raw username and password directly, without redirecting to a secure sign-in page — this is what makes it dangerous, since it provides no interactive surface for an MFA challenge. By comparison, other legacy protocols like EWS and IMAP are blocked at the tenant level before credentials are even evaluated. ROPC remains an active grant type and has been abused at scale in the wild, including an 81-million-attempt credential-stuffing campaign documented by Huntress. This maps to MITRE ATT&CK technique **T1110.004 (Brute Force: Credential Stuffing)** as the access method, with **T1078.004 (Valid Accounts: Cloud Accounts)** covering post-compromise use of the account once ROPC returns a valid token.

EWS:

```
PS C:\Users\Rythem> $cred = "alex.rivera@ACTUALTENANTNAME.onmicrosoft.com:ActualPassword123"
PS C:\Users\Rythem> $bytes = [System.Text.Encoding]::UTF8.GetBytes($cred)
PS C:\Users\Rythem> $base64 = [System.Convert]::ToBase64String($bytes)
PS C:\Users\Rythem> $headers = @{ Authorization = "Basic $base64" }
PS C:\Users\Rythem> Invoke-RestMethod -Uri "https://outlook.office365.com/EWS/Exchange.asmx" -Headers $headers -Method GET
Invoke-RestMethod : The remote server returned an error: (401) Unauthorized.
At line:1 char:1
+ Invoke-RestMethod -Uri "https://outlook.office365.com/EWS/Exchange.as ...
+ ~~~~~
+ CategoryInfo          : InvalidOperation: (System.Net.HttpWebRequest:HttpWebRequest) [Invoke-RestMethod], WebException
+ FullyQualifiedErrorId : WebCmdletWebResponseException,Microsoft.PowerShell.Commands.InvokeRestMethodCommand

PS C:\Users\Rythem>
```

IMAP:

```
PS C:\Users\Rythem> $server = "outlook.office365.com"
PS C:\Users\Rythem> $port = 993
PS C:\Users\Rythem> $username = "alex.rivera@[yourtenant].onmicrosoft.com"
PS C:\Users\Rythem> $password = "[REDACTED]"
PS C:\Users\Rythem> $tcpClient = New-Object System.Net.Sockets.TcpClient($server, $port)
PS C:\Users\Rythem> $sslStream = New-Object System.Net.Security.SslStream($tcpClient.GetStream())
PS C:\Users\Rythem> $sslStream.AuthenticateAsClient($server)
PS C:\Users\Rythem> $reader = New-Object System.IO.StreamReader($sslStream)
PS C:\Users\Rythem> $writer = New-Object System.IO.StreamWriter($sslStream)
PS C:\Users\Rythem> $writer.AutoFlush = $true
PS C:\Users\Rythem> # Read server greeting
PS C:\Users\Rythem> Write-Host $reader.ReadLine()
* OK Microsoft Exchange IMAP4 service ready. 343beec8-2280-4e0a-80fe-8699bd10f8ed (tcpproxy/15.21.0360.006 BACKENDAUTHENTICATE) [TQBxADQAUAAyADIAMwBDAEEAMAAwADIAOQAuAE4AQQBNAFAAMgAyADMALgBQAFIATwBEAC4ATwBVAfQATABPAE8ASwAuAEMATwBNAA==]
PS C:\Users\Rythem> # Attempt legacy LOGIN command (Basic Auth style)
PS C:\Users\Rythem> $writer.WriteLine("a1 LOGIN $username $password")
PS C:\Users\Rythem> Write-Host $reader.ReadLine()
a1 NO Login failed.
PS C:\Users\Rythem>
PS C:\Users\Rythem> $sslStream.Close()
PS C:\Users\Rythem> $tcpClient.Close()
```

ROPC flow

```
PS C:\Users\Rythem> $tenant = "yourtenant.onmicrosoft.com"
PS C:\Users\Rythem> $username = "alex.rivera@yourtenant.onmicrosoft.com"
PS C:\Users\Rythem> $password = "YourRealPassword"
PS C:\Users\Rythem> $clientId = "1950a258-227b-4e31-a9cf-717495945fc2" # Microsoft Azure PowerShell public client ID
PS C:\Users\Rythem> $body = @{
>>   grant_type = "password"
>>   username   = $username
>>   password   = $password
>>   client_id  = $clientId
>>   scope      = "https://graph.microsoft.com/.default"
>> }
PS C:\Users\Rythem>
PS C:\Users\Rythem> Invoke-RestMethod -Uri "https://login.microsoftonline.com/$tenant/oauth2/v2.0/token" -Method Post -Body $body
Invoke-RestMethod : {"error":"invalid_grant","error_description":"AADSTS50034: The user account {EUII Hidden} does not exist in the yourtenant.onmicrosoft.com directory. To sign into this application, the account must be added to the directory. Trace ID: 75ff424f-ac65-4863-9a77-8b189bb4a100 Correlation ID: 0c0ecab8-629a-4ba4-9306-a7dcb3ee13aa Timestamp: 2026-09-01 04:48:02Z","error_codes":[50034],"timestamp":"2026-09-01 04:48:02Z","trace_id":"75ff424f-ac65-4863-9a77-8b189bb4a100","correlation_id":"0c0ecab8-629a-4ba4-9306-a7dcb3ee13aa","error_uri":"https://login.microsoftonline.com/error?code=50034"}
At line:1 char:1
+ Invoke-RestMethod -Uri "https://login.microsoftonline.com/$tenant/oau ...
+ ~~~~~
+ CategoryInfo          : InvalidOperation: (System.Net.HttpWebRequest:HttpWebRequest) [Invoke-RestMethod], WebException
+ FullyQualifiedErrorId : WebCmdletWebResponseException,Microsoft.PowerShell.Commands.InvokeRestMethodCommand
PS C:\Users\Rythem>
```

Incident 2: Location Change Anomaly

Summary:

Morgan Patel's sign-ins consistently originated from Calgary, CA. To simulate a different-network scenario, I connected via VPN and signed in again. Splunk logs show 2 sign-in attempts from an IP geolocated to Singapore at 22:17, although both attempts were blocked.

Error code 399218 does not correspond to a documented Microsoft Entra/Azure AD error code. Since this test data was synthetically generated for the lab, this is likely a placeholder value rather than a real Microsoft status code. The sign-in attempt itself is still meaningful as evidence of the location anomaly (Calgary → Singapore), even without an official code definition.

This map to T1078.004 (Valid Accounts: Cloud Accounts), referenced here as an Impossible Travel / Anomalous Sign-in detection analytic.

2026-08-31 22:17:25	Morgan Patel	none	singleFactorAuthentication	399218	Azure Portal
2026-08-31 22:17:28	Morgan Patel	none	singleFactorAuthentication	399218	Azure Portal

Log

Time	IP Address	City	Country	Client App
2026-08-31 21:33:06	2604:3d09:8d7a:400:e0e8:7ac1:8cf4:a094	Calgary	CA	Mobile Apps and Desktop clients
2026-08-31 21:57:13	2604:3d09:8d7a:400:a58f:f54b:302c:5d97	Calgary	CA	Browser
2026-08-31 21:59:57	2604:3d09:8d7a:400:e0e8:7ac1:8cf4:a094	Calgary	CA	Browser
2026-08-31 22:00:20	2604:3d09:8d7a:400:e0e8:7ac1:8cf4:a094	Calgary	CA	Browser
2026-08-31 22:00:23	2604:3d09:8d7a:400:e0e8:7ac1:8cf4:a094	Calgary	CA	Browser
2026-08-31 22:17:25	162.128.70.83	Singapore	SG	Browser
2026-08-31 22:17:28	162.128.70.83	Singapore	SG	Browser

Incident 3: Brute Force Sign-In

Summary:

Entra ID detected a brute force sign-in attempt against Jordan Lee where 20 consecutive attempts were recorded from the same IP address, each returning Azure AD error code 50126. This pattern is consistent with manual password guessing attack than routine user error given the speed and volume of the attempts. Azure’s built in protection responded automatically after the failed attempt threshold was reached by locking the account and generating error code 50053. This incident maps to MITRE ATT&CK technique T1110.001 (Brute Force: Password Guessing). The root cause is assessed as an external or simulated credential-guessing attempt against a single known username, and the impact was fully mitigated by Azure AD's native lockout mechanism, requiring no manual intervention beyond password reset and user verification.

_time ↕	userPrincipalName ↕	count ↕
2026-08-31 21:45:00	jordan.lee@miolavoro@gmail.onmicrosoft.com	20

After 20 attempts the account was locked:

2026-08-31 21:47:33	Jordan Lee	none	50053	The account is locked, you've tried to sign in too many times with an incorrect user ID or password.	Browser
---------------------	------------	------	-------	--	---------

Limitations

This lab was built entirely without paid tooling. The original plan was to use Wazuh for SIEM log analysis, but configuring the host and forwarding logs consumed more time than the analysis itself was worth, so I switched to Splunk Free as a faster path to actual detection work. Working entirely on free tires also meant several production-grade capabilities weren't available: Entra ID Free doesn't include the Identity Protection risk engine, so sign-in risk (like the impossible-travel anomaly in Incident 2) had to be identified manually through log correlation rather than an automated risk score. Conditional Access, which would normally enforce blocking or MFA step-up automatically also requires a paid Entra ID P1/P2 license, so recommendations in this report describe what a policy *would* do rather than a live control that was tested. Similarly, without a licensed SIEM, alerting and case management were done manually rather than through automated detection rules.

Key Takeaways

This lab taught me a wide range of practical skills I didn't have going in: standing up and administering Entra ID, hosting and configuring a VM, ingesting and querying logs in Splunk, and understanding how an organization actually manages users, roles, and day-to-day security monitoring rather than just the theory behind it. Mapping each incident to MITRE ATT&CK sharpened how I think about technique and impact rather than simply flagging something as suspicious. EWS and IMAP are already deprecated and blocked at the service level, while ROPC remains a fully active grant type that continues to be abused in real-world attacks. This distinction changed how I would prioritize hardening a production tenant. I also picked up basic SPL (Splunk's query language), which I now recognize as foundational to this kind of work in the same way SQL is foundational to data analysis.